Informe de Seguridad: CSRF Vulnerability with No Defenses

1. Título

Cross-Site Request Forgery (CSRF) — Cambio de correo electrónico sin protección contra solicitudes falsificadas

2. Descripción

Se identificó una vulnerabilidad de Cross-Site Request Forgery (CSRF) en la funcionalidad de cambio de correo electrónico de la aplicación.

El endpoint `POST /my-account/change-email` permite modificar el correo electrónico de la cuenta autenticada. La solicitud observada no contiene un token CSRF y la aplicación no impide que la acción sea solicitada desde una página externa.

Se construyó una prueba de concepto (PoC) HTML en el Exploit Server de PortSwigger. El formulario envía automáticamente una solicitud POST al endpoint vulnerable, utilizando el correo electrónico definido en la PoC. Al entregar el exploit a la víctima del laboratorio, se completó el objetivo y PortSwigger indicó que el laboratorio estaba resuelto.

3. Entorno de prueba

- **Plataforma:** PortSwigger Web Security Academy.
- **Laboratorio:** CSRF vulnerability with no defenses.
- **Herramientas:** Burp Suite Community Edition, navegador web y Exploit Server.
- **Endpoint afectado:** `POST /my-account/change-email`.
- **Parámetro vulnerable:** `email`.
- **Acción afectada:** cambio de correo electrónico de la cuenta autenticada.

4. Evidencias

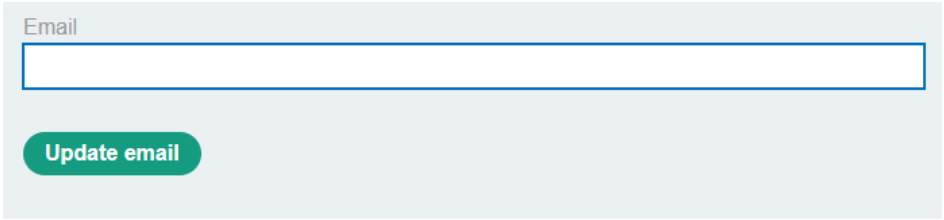
Evidencia 01 — Página inicial



Archivo:

Muestra la página inicial del laboratorio utilizado para realizar las pruebas.

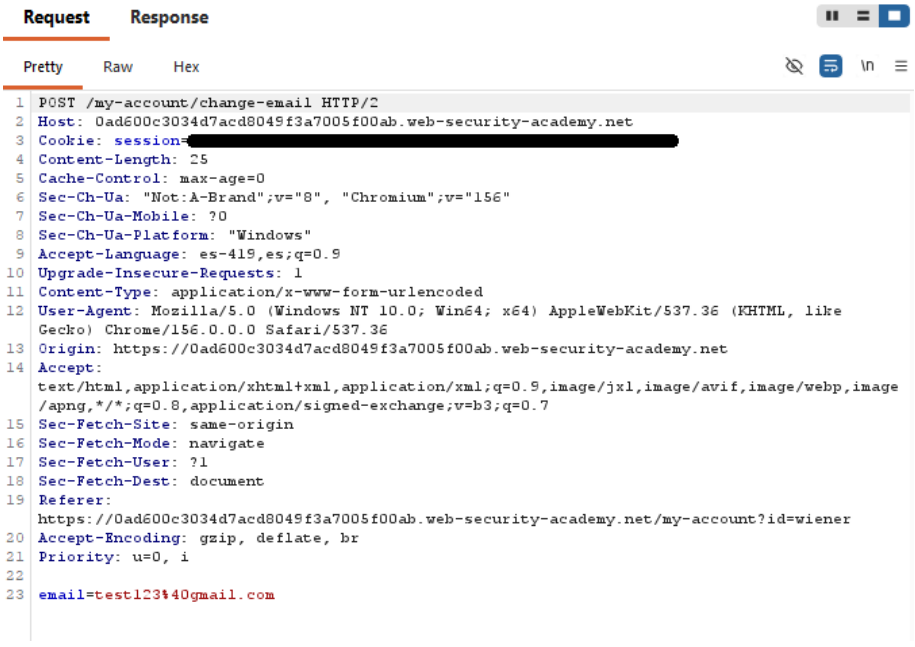
Evidencia 02 — Formulario de cambio de correo



Archivo:

Muestra el formulario legítimo de cambio de correo electrónico disponible en la cuenta autenticada.

Evidencia 03 — Petición de cambio de correo

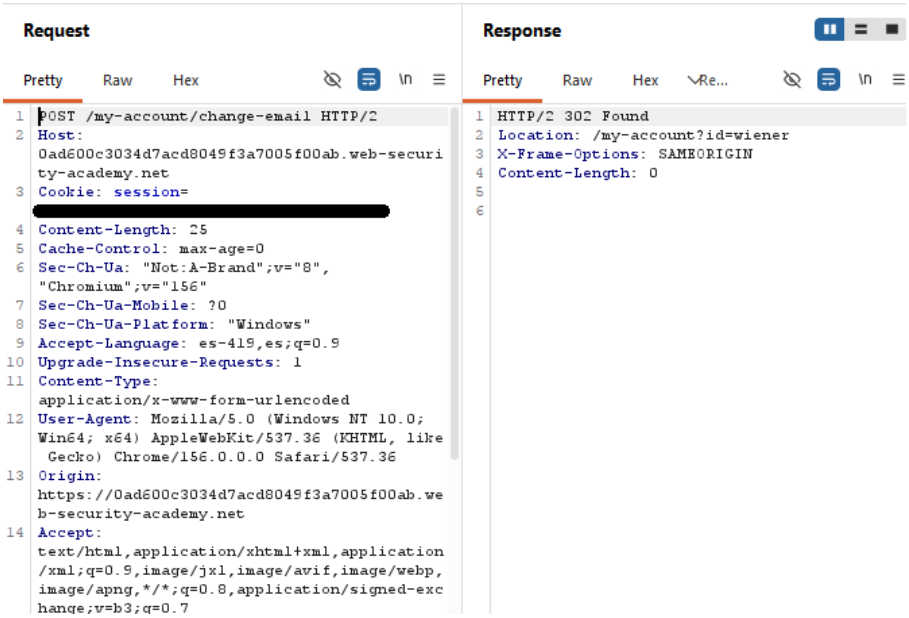


Archivo:

Se observa la solicitud HTTP `POST /my-account/change-email`, que contiene el parámetro `email`. En la petición capturada no se identifica un token CSRF.

Evidencia 04 — Respuesta del servidor

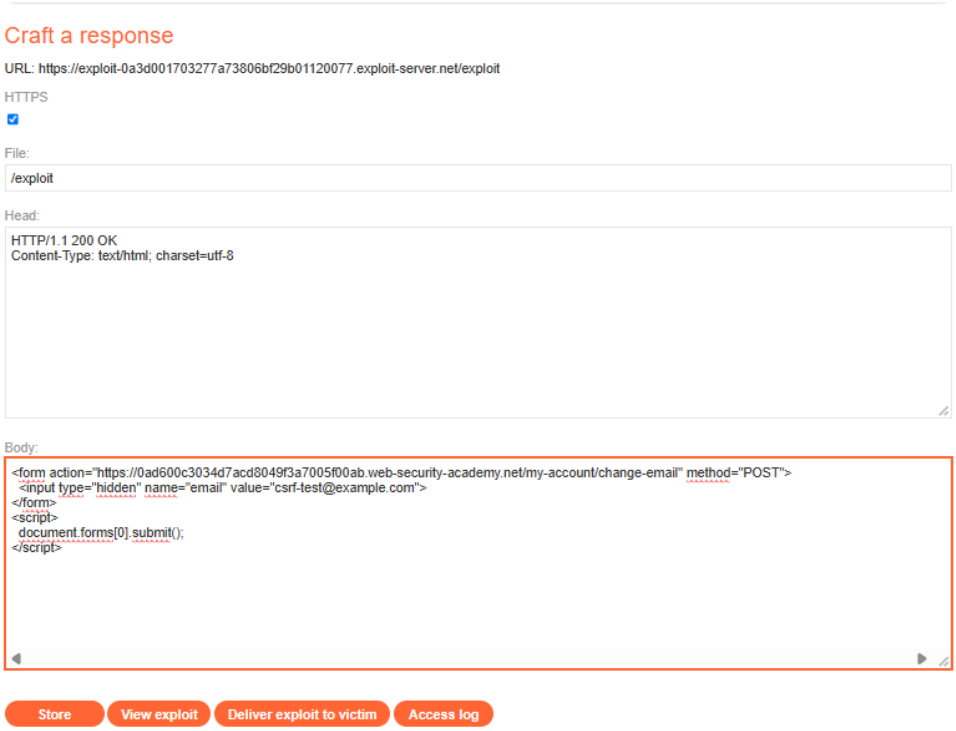
Archivo:



El servidor responde con `HTTP/2 302 Found` y redirige a `/my-account?id=wiener` tras procesar la solicitud legítima de cambio de correo.

Evidencia 05 — Prueba de concepto CSRF

Archivo:



Muestra el código HTML alojado en el Exploit Server. La PoC contiene un formulario que envía una solicitud POST al endpoint vulnerable y un script que envía el formulario automáticamente.

Evidencia 06 — Laboratorio resuelto

Archivo:



Muestra el estado final de PortSwigger, que confirma que el laboratorio se resolvió tras entregar el exploit a la víctima.

5. Impacto

Un atacante podría inducir a un usuario autenticado a realizar una acción no deseada, como modificar el correo electrónico asociado a su cuenta, si el navegador envía las credenciales de sesión y la aplicación acepta la solicitud falsificada.

- **Confidencialidad:** no se demostró acceso directo a información privada mediante esta vulnerabilidad.
- **Integridad:** impacto alto en el contexto del laboratorio, ya que se puede modificar un dato de la cuenta sin una acción intencional del usuario.
- **Disponibilidad:** no se demostró un impacto directo.

En una aplicación real, cambiar el correo podría facilitar ataques posteriores contra la recuperación de cuentas, dependiendo de los controles adicionales de verificación y autenticación.

6. Causa raíz

La aplicación no implementa una protección CSRF efectiva para la operación de cambio de correo electrónico. La solicitud puede ejecutarse sin un token CSRF y no se aplica una validación suficiente del origen de la acción.

La causa raíz es la ausencia de controles adecuados que permitan distinguir una solicitud legítima iniciada por el usuario de una solicitud falsificada desde otro sitio.

7. Remediación

- Implementar tokens CSRF impredecibles y vinculados a la sesión para las operaciones que modifican datos.
- Validar el token en el servidor antes de procesar el cambio de correo.
- Configurar adecuadamente las cookies de sesión con el atributo `SameSite`, como defensa adicional.

- Validar los encabezados `Origin` y, cuando corresponda, `Referer` como controles complementarios.
- Requerir verificación del nuevo correo electrónico antes de utilizarlo para funciones sensibles.
- Registrar y monitorear cambios de datos de cuenta que presenten patrones anómalos.

8. CVSS aproximado

CVSS: 6.5 — Medium (estimación orientativa).

La puntuación es aproximada y depende del contexto de despliegue, los privilegios requeridos, la interacción de la víctima y el impacto real sobre la cuenta. Debe recalcularse para una aplicación concreta antes de utilizarla como puntuación definitiva.

9. Prioridad

Alta en el contexto del laboratorio.

La vulnerabilidad permite modificar un dato de la cuenta de una víctima autenticada mediante una solicitud inducida. En una aplicación real, la prioridad debe determinarse considerando si el cambio de correo puede utilizarse para comprometer la recuperación de la cuenta u otras funciones sensibles.